

On the Estonian Internet Voting System, IVXV, SoK and Suggestions

Abstract. The Estonian i-voting experience is probably the richest to analyze; a country that is considered a pioneer in digitizing both the government and private sector since 2001, and hence digital voting in 2005, yet there are still some complaints submitted, critics and remarks to consider about the IVXV system. In this paper, we introduce a Systemization of Knowledge of the Estonian IVXV i-voting system and propose some added security enhancements. The presented SoK includes applications implemented by election observers in 2023 & 2024 elections, which, to our knowledge, has never been mentioned and/or analyzed in the academia before. The paper also updates the general knowledge about an extra right given to auditors (but not observers) in the June 2024 European election, recent improvements, and recent complaints. Finally, we discuss the current system status in 2024 EP elections, propose our own suggestions to some remaining vulnerabilities, then raise the inevitable question of the approaching quantum threat.

Keywords: IVXV, El-Gamal Encryption, Verkle Trees, vote buying, counted-as-casted.

1 Introduction

Estonia is a small 1.37m population country located in east Europe who gained independence from the Soviet Union in 1991 and joined the European union in 2004 [1]¹. Most Estonian citizens welcomed the general *digital transition* in 2001²; however, when it came to e-voting in 2005 there were some kind of “notable divisions within the society between those who fully trust and those who fully distrust internet voting” as quoted from the **OSCE ODIHR**³ June 2023 report [2].

Although the ratio of citizens preferring i-voting is continuously increasing and has reached 51% in 2023, [3], one can trace a long history of rejection incidences from conservative right parties in [1,2 page8 footnotes16&17] from 2005 up till now; the

¹ The updated number 1.374687m as of Jan 2024 is from (<https://news.err.ee/1609341741/statistics-estonia-s-2024-population-more-than-1-37-million>) which mentions too that most of the annual increase (9000) are Ukrainians. More detailed statistics can be found in (<https://www.stat.ee/en/find-statistics/statistics-theme/population/population-figure#>) which tell us that there are **1.127m “citizens”** as of Aug 2024 and the rest of the population are just residents; it also mentions that there are 296,268 of the citizens **~ 26.28% are from Russian ethnic** nationality.

² Although the science direct article [1] mark 2001 as the start of the digital transition (e-government) in Estonia, we notify (based on a previous reviewer objection) that Estonia has databases in their government since the 1990’s.

³ OSCE stands for Organization for Security and Cooperation in Europe, ODIHR stands for Office for Democratic Institutions and Human Rights; for IVXV to be used in voting for the European Parliament elections, European entities ought to approve its security.

situation was emphasized in 2023 when the internet votes flipped the election result for one of those parties, *EKRE*. The distribution of internet votes was completely different than that for poll station paper votes as shown in the curves in [4]; analysts due it to the society division mentioned above (i.e., it's expected for the distribution to reflect the parties' conventions on the voting method). Still, there were some complaining movements that continued persisting to the 2024 European elections [5].

Since most rejections come from right parties, a note about the effect of Ukrainian war on Estonia being the closest neighbor is appropriate; according to [6] there were Russian attacks on the system, but the authorities say it was properly defended⁴. On the political impact, we suffice with this article [7]; even if it was politically biased, it points out to the economic status with more refugees that the writer projects will seek Estonian citizenship, and thus can vote. Also, some parts in the context of the *OSCE* report, [2, pages 15-16, footnotes 45&48], implies that Estonia is not very strict in giving citizenship for stable residents and their born children⁵. The paper does not aim to dig deeper into political details; however, it is important to enlighten the reader about what seems to be the roots behind the split of opinions in the Estonian society.

Being aware of the Estonian election environment and the involved players, we proceed into the technical and cryptographic details; hence, the rest of the paper is organized as follows. Section 2 reports some recent important activities by the i-voting opposing community that have technical merit, while section 3 marks briefly the milestone steps through the evolution of the Estonian i-voting system. Then section 4 explains in detail the current version of IVXV ending with an important attack that was fixed before the 2023 elections, while section 5 goes through improvements that were done or proposed in 2024 before the European elections. Section 6 discusses the remaining vulnerabilities of the system along with suggested solutions some of which are proposed by the authors. Finally, section 7 introduces suggestions for further future research and section 8 concludes the paper. Further details on the suggested usage of Verkle Tree is provided in Appendix A, while Appendix B contains a brief survey on post quantum i-voting research attempts and El-Gamal replacements proposed in the literature.

2 Recent Opposition Activities with Technical Merit

A technical incident that gained some publicity in 2023 elections [8] was done by the same computer scientist observer⁶ in [4]; he voted using his own Python code

⁴ We clarify that although [6] is written in Canada, it is about Estonians being able to vote remotely while in Canada and the risks involved. We also note that there was a question in [8] about the fears of Russian interference or taking advantage of the IVXV vulnerabilities.

⁵ It is not of our concern whether OSCE finds this fact good or bad; we are just stating the facts. Also, we decided to keep the article [7] because we believe it is our obligation as an SoK paper to inform the reader with the whole picture even if it involves some extremes.

⁶ The word "observer" is a term used by IVXV to acquire certain access rights during the election (as opposed to "auditors" as we will detail shortly). On the other hand, the term

[9,10], meaning that he has overridden the official voting application that voters should download to deliver their vote to the system. This gives an alarm that the voting application is not authenticated by the system, which was noticed by the OSCE report [2, page 8]⁷; there were a mention of some wrong district votes too [11], but the report says they were corrected except one vote. It is the authors' impression from all read material that most submitted complaints get rejected based on passing a 3-days *from election* deadline without objective investigation, then the vulnerability get handled in the following election⁸. A recent complaint about the decryption of invalid votes after the current 2024 European elections was also rejected objectively in [12]. Among the three listed reasons, being an *observer* not an *auditor* seems to be the dominant one, where auditing is organized by the State Electoral Office in all elections [13]. According to [14, Conclusion-page 60], generating proofs of correct decryption of invalid votes was remediated in code by the thesis writer to auditors only in 2024; however, the file containing the decryption of invalid votes is only accessible to auditors [14, page 22].

The recent European parliament elections were accompanied by some newer actions from the i-voting opposing community [5,12,15,16,17]. The same observer mentioned above has developed some kind of shadow e-voting site called *virtual threshold survey* [15] encouraging citizens to vote again on it as a check (although no evidence of considerable participation ratio). Also, a criticizing paragraph about IVXV strategic mistakes from a researcher in *Cybernetics* TUT is being circulated online [16]⁹; however, a clarifying response told us that “*Cybernetics* is NOT the same institution as *Cybernetica* (even though it shares some common history, but this ended more than 25 years ago) and the researcher Ago Samoson is in no way affiliated with *Cybernetica*, nor IVXV development”, where *Cybernetics* split in from *Cybernetica* which is the company behind the current Estonian internet voting system

“**Computer Scientist**” taken from the title of [4] is extremely rejected by IVXV representatives and supporters who describe Mart Poder as “**A hobby hacker activist**”; the OSCE report referred to him as “**someone with sufficient programming skills**”

⁷ We received some rejecting opinions that it is considered a system strength and a transparency quality that voters can vote using their own applications; however, the OSCE report described it as “**could present a cyber security risk**”, and even the IVXV team did not acknowledge this point of view when we mentioned it in [43] as a possible reason behind not authenticating the voting application. In any case, we tried to provide solutions that satisfy both points of view in section 6.1

⁸ This will be detailed further through the paper; see footnotes 14,15, 22 for older fixes, and consider the system' response to all discovered exploits they fixed afterwards as detailed in sections 5.

⁹ The statement in [16] about “*a strategic mistake*” was made on March 2024, he made another (more moderate) statement on June (<https://arvamus.postimees.ee/8036445/ago-samoson-selline-kontroll-parandaks-e-valimiste-usaldusvaarsust>). People from the system says that although AGO Samoson is a researcher in Tallin University of Technology (TUT) School of Information Technologies, TalTech, he is specialized in NMR and materials science (<https://www.researchgate.net/profile/Ago-Samoson>).

since 2014 (partnering with -*Smartmatic* [3,18]) as we will detail in the following sections.

However, in addition to the complaint in [12], we find the story of an earlier complaint about the election desktop also alarming; a first complaint granted the observer (on 23/2/2023) a permission to see the content of the backup copy of the boot hard disk used in key creation to have full confidence there is no malware in the computer memory during key creation [19]. The observer took the photo shown in Fig.1 when the disk inspection took place (28/11/2023); it can be concluded from [17] that he pursued the matter further to the supreme court where they responded that *"voting results cannot be compromised with malware, because with the help of the reading certificate issued when determining the voting results, the compromise would be revealed immediately"*¹⁰. Later, on Aug 2024, a commentator from IVXV team stated (in an earlier reviewers' report) that they admit the risk and that it had been taken care of.



Fig.1: image taken from [17]; according to the observer, this is the computer used in key creation which was supposed to have an authentic Windows10 operating system, but the operator didn't notice that DigiDoc4, Notepad++ and RamDisk tools are also installed on it.

Finally, we haven't seen yet an *OSCE-ODIHR* report on the 2024 European elections, but another scientific report from ***the cyber security committee of the Academy of Sciences*** has been already handed to the election organizers [20]. Although the report is still under review and are not published yet, Google translating the minutes of the last committee meeting [21] on 3rd of June tell us they *have identified 6 threats whose risk class is higher than small*.¹¹

3 A Brief on System Evolution

As mentioned earlier, digitization has been in Estonia for more than 20 years, even before 2001, and has extended to include the private sector hand in hand with the e-government; e-ID cards existed since 2002, Fig.2, and electronic transactions is the casual behavior of the Estonian citizen. More details on digital system architecture and components like *Xroad*, *KSI* private blockchain is out of the scope of this paper

¹⁰The official progress of events in: (<https://www.riigikohus.ee/et/laheidid/?asjaNr=5-23-40/2>)

¹¹ A committee member commented (in a non-publicly available statement) on 14/8/2024 that all the 6 threats are of risk class medium (11-13).



In May 2018, Estonian authorities officially declared a persisting problem that started to appear in some rare incidences of duplicate RSA keys since 2011/2012. Such “rare” incidences where citizens were asked to re-install the Java Applet on the cards at PPA (the issuing authority) stations (otherwise the card transactions will be suspended after a certain time limit), became more frequent with time; hence providing more data & information for researchers to analyze. Then, it was proven that the ID card manufacturing company, **Gemalto**, generated the RSA keys outside the chip (could be to fasten the process) which violates the agreement rules and gives a chance for the key pairs to be copied and repeated. A lot of interesting details on how the analysis was done can be found in the presentation [23] and the paper itself [24]; more faulty keys issues¹² can be found in the PhD of the same researcher Arnis Parsovs [25], and in [26]. Also, other RSA vulnerabilities were discovered in [27].

According to [1], this was a global crisis for the company which was sued in many other countries around the world; Spain and Slovakia [28] replaced all the physical cards while Estonia fixed them remotely. Then, they changed the company to **IDEMIA** [29] and, as recommended by [23], moved to threshold cryptography and homomorphic encryption; the Estonian i-voting system IVXV also uses **384-bit Elliptic Curve** Cryptography ECC with El-Gamal Encryption, but the list of authorized votes is still signed using 2048-bit RSA key. Note that, this means Estonian digital IDs will also have to migrate into post-quantum plans soon.

¹² Example errors include codes printed too dark which made them readable using torch, without opening envelope (happened twice in 2002 with the old company then again in 2018: <https://news.err.ee/886313/new-id-card-issue-codes-can-be-read-using-torch-without-opening-envelope>), duplicate email addresses in certificates, issuing certificates with incorrectly encoded public keys, failing to revoke certificates of deceased persons.

3.2 Estonian i-voting before IVXV

As a preface, this section gives a condensed brief on how the Estonian i-voting system has evolved from 2005 to its final form as IVXV.

According to all available references, the main design theme of a double envelope protocol sending voter signed (first encrypted by the election public key) ballot to the vote collector was there since 2005. Then, based on [sec.1 of 30,31,32], we mark 2 milestone step transitions:

- In 2011, a student named *Paavo Pihelgas*¹³ demonstrated a proof-of concept ballot-manipulating software that relied on the absence of an acknowledgement from the vote collector to the voter that his/her vote was received. Hence, the ability for voters to verify their votes was first introduced in 2013. However, several flaws were discovered in 2014-2016 that could maliciously alter the vote or the QR code; until *Cybernetica* partnered with *Smartmatic* to produce the QR verification code in its current form in IVXV¹⁴.
- Then, with the appearance of other comparable e-voting systems (ex. *FLEP* in France & *SwissPost* in Switzerland), rich material was available for cryptographic research and lessons were learned. Hence, the 2017 and current version of the Estonian i-voting, IVXV, added a vote-registration service to guarantee no vote dropping, a shuffling re-encryption mix-net for vote privacy, and a *Schnor* based NIZKPs non-interactive zero-knowledge proofs of correct decryption as will be detailed in the next section.

4 IVXV

In this section, we explain the design and structure of the Estonian internet voting system, IVXV, as described in the official documents [33]. Then we detail an important cryptographic attack and how it was fixed before the 2023 Estonian elections.

4.1 Brief Factsheet

For a factsheet summary, the developing companies are *Cybernetica-Smartmatic*; the voting device must be a desktop PC (mobile voting is still postponed at least to 2025 [34]); voting on the other hand can be done using *mobile-ID*, *Smart-ID*, or any digital

¹³ According to [32] the student filed a complaint to the Estonian Supreme court requesting to nullify internet votes in 2011 elections, but his complaint was dismissed for passing the 3 days limit (<https://www.riigikohus.ee/en/constitutional-judgment-3-4-1-4-11>)

¹⁴ The verifying extension, was only added in 2013 based on S. Heiberg & J. Willemson suggestion (<https://ieeexplore.ieee.org/document/7001135>), possible attacks were discovered in (<https://dl.acm.org/doi/10.1145/2660267.2660315>) and then the verification was improved on 2016 (<https://research.cyber.ee/~janwil/publ/ivxv-evoteid.pdf>)

identity integrated in the *web-eID*¹⁵; *multiple voting* is allowed to avoid coercion or vote buying (only last vote is counted and a poll station vote overrides all i-votes); **El-Gamal Homomorphic** Encryption scheme is used to encrypt votes then the encrypted vote is digitally signed by the voter (double envelope); optional vote verification can be done by voters (through *QR codes* using a second mobile device) within 30 mins of voting with a max of 3 times; **Mixnets** are used to scramble votes before decryption to preserve ballot secrecy. The *election secret key* is divided into parts issued to the members of the *Election Commission of the Republic*, such that decryption requires 5 out of 9 parts. Finally, there is **an auditor application** (could be run by anyone) that verifies the cryptographic proofs provided by IVXV on the election published output data.

4.2 System Architecture & Voting Steps

The system architecture and voting steps are depicted in Fig.3; the voting steps could be summarized as follows

1. The voter installs the voting application¹⁶, sometimes abbreviated as **VA**, on his/her PC.
2. After submitting the digital identity ID, the voting application checks the eligibility of the voter to vote through *the registration application*, **RA**, and if eligible displays the candidate choices for that voter (according to district if it's a local election).
3. The voting application encrypts the voter choice using the election public key (El-Gamal encryption), adds the user signature on the encrypted vote (with the voting application running on the voter's PC and after the voter's approval, *the voting application has the right to sign a message with the voter signature*), adds also the *timestamp certificate*¹⁷ received from the registration application through the vote collector *after verifying the signatures of both*, and then sends the double envelope ballot to the vote collector (sometimes abbreviated as **VC**).

¹⁵ The newer IVXV version used in EP-2024 included extra **web-eID assistance service**, **Smart-ID assistance service**, and more other processes to scale horizontally enabling the usage of different digital identities (see section 2 of the architecture file and secs 8.5-8.6 of the protocols file in [36]). The web-eID solution (<https://www.id.ee/en/article/web-eid/>, <https://github.com/web-eid/web-eid-system-architecture-doc>) enables the use of different digital identities available in Estonia as a part of applying the European Union web-eID project for all public key cryptography digital identities across Europe.

¹⁶ Sometimes called the voter application in official documents, but we prefer to follow the naming convention in [31] to make it clearly distinguishable from the voter device.

¹⁷ Before, the timestamp certificate was used to distinguish the last vote of each voter, and also for checking the possible verify duration of 30 mins; in the 2024 version *the certificate* sent by the Registration to the Collector *is a signed CONFIRMATION* (by RA) that contains the original request (now called **ORDER**) sent (and signed) by the VC, along with the *timestamp*. The VA should check both signatures in the certificate it receives.

4. The vote collector application validates the voter's signature; after validation, the signature is removed, and the encrypted vote is added to the list of votes stored in the *Ballot Processor* to be mixed and shuffled by mix-nets¹⁸, then decrypted at the counting phase; the ballot processor removes multiple votes after voting is closed, and before sending to mix-nets.
5. The vote collector sends a verifying **QR code**¹⁹ to the voter for optional vote verifying (through verification application) using a second smart device.

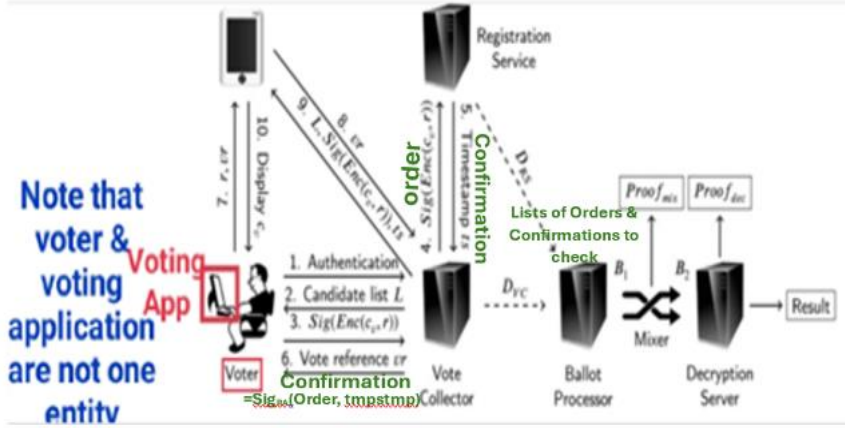


Fig.3: a diagram describing the architecture & the steps of the Estonian voting system, adopted from [1] (we added some colored remarks to remind the reader to distinguish between the voter machine and the voting application when it comes to attacks & vulnerabilities; we also added updates in IVXV 2024 version in green)

4.3 Cryptographic Details of Last Fixed Attack

We find it significant, also gives a closer look into the used cryptographic primitives, to explain the exploit introduced in [31]; Fig.4 omits the voter signature and mix-nets parts and concentrates on the parts involved in the exploit and the introduced possible attacks.

¹⁸ IVXV uses *Douglas Wikström's Verificatum* (<https://www.verificatum.org/>); the package itself provides a verification application, and so does IVXV (and several other projects [30])

¹⁹ According to [9], there were a revealing incident of the president vote through his QR code: he voted online in front of cameras, showing his QR code, to encourage citizens; someone took a snapshot of the QR code and revealed his vote. The incident was mentioned in the context of doubting privacy and hence protection from coercion and/or vote buying.

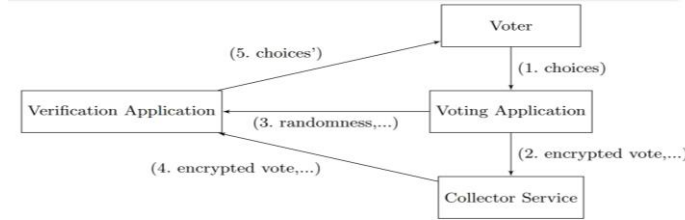


Fig.4: the part of vote casting and verification taken from [31]

Let the election public key be " y " with corresponding secret key " S_k ", and " g " be the generator for El-Gamal encryption²⁰; Hence, the equation « $y = g^{S_k}$ » holds.

-To encrypt a vote " v " the voting application generates a random number " r ", so that the encrypted vote is $(C_1, C_2) = (g^r, y^r v)$

-The verification application, working instantly within 30 mins, receives " r " from the voting application (hidden in the QR code) and calculates $v = C_2 / y^r$ where the voter is assured when the displayed " v " is the same " v " he/she voted for.

-When counting votes, the election authority uses the election secret key (S_k) and the El-Gamal encryption known equation « $y = g^{S_k}$ » to calculate $v = C_2 / ((C_1)^{S_k})$

In the older design, the verification application only received C_2 from the vote collector. This gives a malicious voting application the chance to manipulate the encrypted cipher text by sending different values of C_1 for the same C_2 . Without checking C_1 value, the verification application will not detect a fraud if the voting application sent a wrong " r " value to the vote collector, r' such that $y^r v = y^{r'} v'$ to deceive the vote collector into recording v' as the voter's intended vote.

Long story short, the authors found three possible manipulations all with a simple fix: making the vote collector send the whole encrypted pair (C_1, C_2) to the verification application which should also verify that $C_1 = g^r$ as was finally done [35, lines 77-83 & 141-146 in code and the exception is thrown at line 60] on 23rd Feb 2023 just before March 2023 elections²¹. The authors alarmed that it is concerning [31, sec 3.6] that such a straightforward vulnerability wasn't noticed earlier, and then criticized the quality of IVXV in general [31, sec.4].

5 Enhancements Against Vulnerabilities

In addition to extending IVXV to support voting with more kinds of digital identities like web-id and mobile-id, [36], the European parliament election version IVXV

²⁰ We've mentioned in section 3.1 that a 384-bit elliptic Curve is used for the group field.

²¹ The fix was after the time of publishing [31], that's why the authors stated: "*up till now the vulnerability was not fixed*" and that whenever they asked the reply was "*we're working on it*".

1.9.10-EP2024 included many other improvements. This section details three of them which targeted discovered and/or criticized exploits.

5.1 Decryption of Invalid Votes

Another improvement was added to IVXV on 30th May 2024 [36]²², just before the European Parliamentary elections on 3rd of June; invalid votes are thrown in a separate file and **ZKPs (Zero Knowledge proofs) are generated for correct decryption of invalid votes as well.** However, election observers are not allowed to verify those proofs as we discussed the earlier complaint.

Why not reveal invalid votes?

As mentioned in section 2, there was a lot of debating and complaining about not allowing observers to view the decryption of invalid votes; however, the reasons stated by the state election service in the supreme court decision [12] do not match accurately those explained in [14].

- Reasons 1&2 in [12] talk about the technical infeasibility of decrypting invalid votes after the election and how this needs parts of the secret election key (issued only to members of the election commission); on the other hand [14] explains how the IVXV version used in 2024 already decrypts invalid votes in a separate file, and this can be traced in the opensource code [36]. In general, election data gets destroyed a month after the election.
- The 3rd reason in [12] of “*not knowing in advance what the invalid ballot contains and it may be an attack*” is rationalized better in [14] as the possible reveal of some information about the voter of the invalid vote, or more severe the threat of **encoding attacks** described in [37, sections 3.3 & 4.1] where an adversary can know the votes of several voters if able to submit a carefully crafted invalid vote and also view its decryption. Hence, the rational is to shrink the circle of trust into auditors only, which is not even needed if invalid votes were rejected earlier by the vote collector as [14] suggests. In fact, tracing the **number of invalid votes** in the official statistical site [38] to be **exactly 1**²³ in the last three local elections since 2021 makes it look quite suspicious; the doubt includes anyone who can see the votes and should be eliminated completely when range proofs get deployed.

5.2 Integrity Checks

Another problem that was mentioned in the OSCE report [2] is that there's no cryptographic proof for **the deletion of multiple votes or ill-formed vote ballots**; i.e., the authorities are assumed trusted regarding not deleting or adding extra votes at this

²² The GitHub in [36] shows that this version of IVXV is named 1.9.10-EP2024, while the previous fixed version in Feb 2023, [18], was named 1.8.2-RK2023.

²³ The number has become 2 in the European elections (after earlier preprints of this paper has been circulated)

step. Quoting their own words "*The critical step of removing the votes overwritten by another vote cast on the internet or in a polling station was not audited*", "*An insider with sufficient resources to alter the system, if able to do so undetected, could manage to control which votes are removed and therefore partially impact the results*". This was viewed by [39] as trusting the vote collector and registration applications to not collude²⁴, otherwise it would be possible to drop ballots; the *Ballot Processor* in Fig.3 could also manipulate the ballots (assumed trusted by the system). To elaborate more, yes there are decryption proofs that what goes into the *mix-nets* is exactly what gets out of it to be finally decrypted, and yes there is the possibility to design a public independent decryption proof verifier [30], but there was no cryptographic proof for the transition from the total list of votes to the "to be counted" list of votes; what is called the *processing stage* and we believe is part of *universal verifiability*.

IVXV Adopted Solution

What we believe (section 6.2) is a partial protection from this vulnerability was integrated into the audit application of IVXV through a file named ***Integritytool.java***, [40], published on 30/5/2024 just before the European parliament election; however, the details of the solution were only published academically in [41] as of 23/12/2024. The authors state that they have contacted IVXV team with their proposed checks to detect insider risks at the processing stage, and that it was successfully deployed. The proposed checks are applied to the Ballot Processor data; the Ballot Processor is an offline computer [41/section 3.A] that performs some processing on this data (Fig.5) to then input the list anonymized votes to the mix-nets.

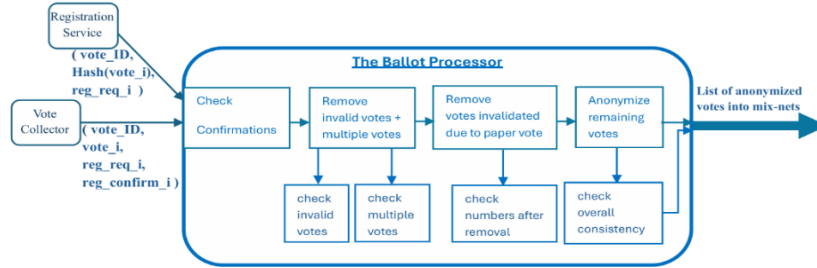


Fig.5: The (modified) processing stage after adding the *integritytool.java* file

Since the votes file (along with the necessary checksums) is cryptographically signed after each step, most examinations depend on comparing SHA256 hashes of subtotals, totals, and individual votes before and after each step. Also, *count-based validation* was needed to detect certain types of manipulations like adding the removed older multiple votes to the list of anonymized votes; i.e.,

$$\boxed{\text{Count (original votes file)} - \text{Count (anonymous valid votes)} = \text{Count (multiple votes)} + \text{Count (replaced by paper)} + \text{Count (invalid votes)}} \dots \text{Eq(1)}$$

²⁴ Although Jan Willemson stated in his 2022 paper, [30], that the registration service makes it "impossible" to drop ballots, more tight statement about the trust assumptions involved in his newer (2023) co-authored paper [39]; we also have mentioned before that this is much more clarified (with figures) in the newer IVXV protocols file in [36].

Note that the Ballot Processor receives the list of all votes along with any necessary confirmation checks [36/protocols.pdf/Fig.6.3]; i.e., the integrity of those cryptographic checks (like the *Count (original votes file)*) depends on trusting the vote collector and the registration application to not collude [39]. Hence, what was mitigated by [40,41] is **the risk of a colluding Ballot Processor**.

5.3 Session ID check

A possible attack by a malicious voting application that could deceive even verifying voters was discovered by Olivier Pereira in [32]; a malicious application could fake a system crash to deceive the voter to vote again. By doing so, the application can take the voter signature twice (generate another "r" value to construct a new encrypted vote in the background); hence while showing the voter the QR code of his/her choice, the system will consider it an old vote and will use the new vote.

Previous Suggestions

-The author suggested a few mitigations, we have no clue that any of them was adopted, except storing a *voteID* field with each vote.

-One may also recommend advising voters to double check the number of voting transactions with other available e-government services available in Estonia like *myID* service (<https://myid.skidsolutions.eu/en>), especially if their device suffered a system crash while voting. Although could be complicated to design, as it requires searching the final anonymized list of votes, the QR code could contain a flag on whether this is the last vote or not²⁵; other embedded options which are easier to design and provides more information will be discussed in section 6.

-Another simple safeguard for this specific problem only, [42], would be to force a time interval between votes; *the verification interval, 30 mins, seems a suitable choice*. However, this must be accompanied by heavily warning voters to close the application then reopen again after 30 mins; if the voter eID remained available on the voter's PC more than 30 mins, a *Ghost Click attack* becomes possible [32] and a malicious voting application would have enough time to submit silently without voter's knowledge.

IVXV Adopted Solution

Although not publicly advertised, a solution to this attack was also added on 30th May 2024. The code was updated to simply check the session ID is still the same before generating the QR code; the code documentation [43, lines 22 & 103] highlights that this "**prevents reusing session ID until it is deleted from a database or expired**".

According to [36/section 8], the **PKIX** timestamp protocol-based registration service is used both to record the time of casting the vote and to register the electronic vote in an external independent service.

²⁵ We think the timestamp alone is not enough to help the voter detect a problem; in case of a faked system crash, the voter may not notice the difference and say "OK, maybe the system records the time when I started the voting attempt, not when it has ended"

Tracing a little deeper, [44], the two methods *SessionStatus.Read* and *verifyStatusReadResp* can detect a fake restart if the server expires or revokes the same SessionID post-crash (or faked crash with another vote). The current code **relies on timestamps expiration**, so a malicious app reusing an unexpired SessionID could slip through unless tighter server-side tracking is in place.

On the other hand, according to [36/section 8], the *PKIX* timestamp protocol-based registration service is used to record the time of casting the vote, while the *rsyslog* service records the logging time in milliseconds which make it possible to use the *Guardtime* module to ensure the integrity of the logs.

6 Remaining Vulnerabilities/Issues

This section starts with a preface that summarizes the status quo of the Estonian electronic voting systems, then follows with some remaining vulnerabilities and proposed mitigations (whether by the authors or in previous literature). As we expect IVXV is approaching the end of an era and will have to face the quantum computing threat very soon; we will discuss the post-quantum version of our suggestions as we go, then seal with possible post-quantum system upgrades.

6.1 The Status Quo of IVXV

Many academic research papers, in addition to pointing out some attacks [31,32,37], have introduced a holistic criticism to IVXV; [31] analyzed *IVXV public information* as *satisfying* only 1 (minimal restriction on disclosure of vulnerabilities) *out of 9 quality metrics*²⁶ and warned from the possible existence of hidden vulnerabilities; [37] demonstrated (through the analysis of possible privacy attacks) that *IVXV is vulnerable to attacks against vote privacy in those threat scenarios that were considered for it originally*; [39, sec. 5.1] discussed the different trust assumptions of IVXV including software components and key holders, in this context [37] also discussed that Vote Collector is trusted on the privacy of encrypted votes.

Although those papers were all written in 2023 analyzing the version used in June 2023 election or earlier, and although we did trace many improvements in the current 2024 version IVXV 1.9.10-EP2024²⁷ meaning we could have missed some, we know the newest version is the one analyzed in the most recent report [21] which identified 6 threats with risk level higher than small. The report was done in collaboration with

²⁶ The quality standards are from an earlier paper by the same authors (FC’21, *New standards for e-voting systems: Reflections on source code examinations*)

²⁷ There is not enough English documentation yet to accurately trace all changes in the newer version; GitHub history shows 897 changed files with 34,059 additions & 10,830 deletions. Translating available pdf files from the Estonian language shows the work done in integrating different kinds of digital identities, and in coordinating with the XRoad service (X-tee); also a whole section (6 in the protocols file in [36]) is dedicated to the registration service and its communication with online (RIA), offline (RVT) and other IVXV services.

the election authorities (i.e. not biased against IVXV); also, the OSCE 2023 report [2] pointed out to some issues only some of which were resolved.

The IVXV team on the other hand sticks to the fact that there is no proved error in the election results; however, with QR verification ratio of 5.5-9.9%²⁸ as stated in the official i-voting statistics site [38], this does not really prove beyond reasonable doubt that no encryption pairs were manipulated. Also, as a general attitude, IVXV does not advertise its progress to researchers. The improvements in section 5 were discovered through searching the academic literature and/or tracing the code; the authors of [31] were not informed of the fix till the paper was published. When the authors of this paper contacted them in Feb 2024, [42], they did not mention that they are already working on the mitigations deployed on 30th May 2024; they gave an impression that either they do not care about such exploits, or they are impossible to fix. The official English site, [45], still have the new version files only in the Estonian language after nearly 11 months from the update. There are other previous responses we detailed through the paper; all of which accumulates suspiciousness and/or diminishes their efforts to improve the system robustness.

6.2 The Voting Application

Even if the IVXV solution discussed in section 5.3, [43], completely protects from the Olivier Pereira attack, [32], it is not a general solution to the voting application vulnerability. The authors of [31] commented on the voting application being the only unrevealed part of IVXV code as an open source, while [39] identify this fact as a trust assumption. What is more of a threat is the incident of overriding it in 2023 election, [8,9], which proves that it is not even authenticated; accordingly, the OSCE report [2] notified about the risk of not authenticating the voting application. A clear obvious vulnerability here comes from the possibility of downloading a malicious voting application; this leaves it as an open challenge for adversaries to design the most possible malicious code they can come up with. Having a ~ 90-95% probability that the voter will not verify the vote, a ratio that could even increase by social engineering to target those who are not likely to verify, makes the risk level more severe.

Another possible risk is for vote buyers/coercers to do what the authorities haven't done; i.e., develop a fixed candidate voting application and authenticate its usage through execution attestation on the voter PC²⁹ before transferring the money. This

²⁸ The older highest recorded verification ratios are 6.7% in 2021 elections, then the European 2024 elections showed a significance increase to 9.9%. It's not clear whether the ratio is per voter or per vote (in case of multiple voting); however, considering 2023 elections, since total cancelled multiple votes is 12,119 (10,787 multiple + 1,332 replaced by paper) out of 313,514 total i-votes (~ 3.86% with a max. of 9.27% in 2021 elections), we don't think this will make a significant difference.

²⁹ Remote execution attests were originally discussed on Intel SGX (which is available on many new PCs in the market: <https://www.intel.com/content/www/us/en/architecture-and-technology/software-guard-extensions-processors.html>), and it exists in other processor

DarkDAOs idea was discovered by [46] in 2018 as a possible threat to decentralized voting in DAOs using governance tokens, but it could happen here too; the authors published a follow-up in 2023 [47] with a GitHub code³⁰. Also, another group of researchers have recently discussed in [48] the newly evolved threat of using new technologies like TEEs and blockchains by coercers or vote buyers; meaning that those are not less probable threats.

§ A general solution to all the above would be ***to authenticate the official voting application***

- A simple moderate safeguard is to publish its file digest (hash SHA256 for its code for example) and encourage voters to run a check before using it; the Electrum Bitcoin wallet already gives this option when downloading [49], so it could be easily implemented. Although this is still very much voter dependent, one can count on users performing system recommended pre-checks with higher ratio than post-checks (like the $\leq 10\%$ ratio of QR codes). As a second safeguard for QR-code checkers, the verification application could also display an extra message with the vote saying that “*You voted using (the official/a different) voting application*”. This fulfils the system philosophy³¹ of giving suspicious voters the freedom to code and use their own voting application (or maybe use a one written by a political party they trust more).
- Another solution we believe is more intact (since it is not optional) is to assign a signature & authentication key pair to the voting application like the rest of involved applications in the system. Then the election authority can allow only usage of a pre-registered private voting applications with a stored public key at the voting server; this way, the election authority can also scan the private voting applications for any malicious or vote buying code before granting usage rights. However, another issue remains in this solution in ***how to inform a non-verifying voter that the vote was rejected because he/she has installed a malicious voting application.***

We think, [42], the vote collector application could deduce the IP address of the voter machine from the first contact with the voting application, then it can *send a* direct warning message; something that pops up on the voter screen “Be careful, this is not the official voting application”. The use of a feedback channel was also one of the suggested mitigations in Olivier Pereira paper [32] and a clear message about the application can mitigate his fears of deliberately delaying; it as long as it is received

companies like Apple and even mobiles as well. So, we can assume there's a considerable probability that the voter PC can support it.

³⁰ The same authors simultaneously participated in another paper which suggests a solution that TEE provides only execution attests after submitting ***proof of Complete Knowledge (CK)***; <https://medium.com/initc3org/complete-knowledge-eecdda172a81>, <https://eprint.iacr.org/2023/044>

³¹ Although the response in [42] does not give this impression, some of IVXV team respond that “*being able to vote with your own-made application is considered as a measure contributing to the transparency of the system in Estonia*”; in any case, the solutions we suggest support this feature.

before voting is closed, the voter can vote again either through a more secure device or in a poll station. Although the authors of this paper are not very familiar with the technicalities of the down network layers involved in implementing this informing mechanism, it is feasible to implement³²; IVXV already acquires knowledge of the IP address to calculate ratio of abroad voters as stated in [38].

Finally, all the above solutions could be straightforward post-quantum by choosing post-quantum hash functions, and using the same post-quantum digital signature scheme the system will migrate to.

6.3 Range Proofs

To eliminate any complaints (like [12]) and/or risks (ex. [37]) accompanying invalid votes, it is much safer to prevent them from reaching the Ballot processor at all. The thesis in [14] suggested the use of a Zero Knowledge Proof (**ZKP**) check by the Vote collector application to check the validity of the vote it receives from the voting application without revealing it and hence reject invalid votes before being added to the list of votes.

-The thesis preferred the use of **Range Proofs** as opposed to **Set-Membership proofs** for their simplicity and suggested some mitigations to the discontinuity of the set of vote choices. The authors proposed Range Proofs that are based on **Bullet Proofs & Pederson Commitments**, since they depend on the Discrete Logarithm problem like El-Gamal encryption used in IVXV. They considered general purpose SNARKs (Succinct Non-Interactive ARGument of Knowledge) based on polynomial commitments not suitable for El-Gamal based voting systems.

-The original paper for Microsoft *ElectionGuard*, [50], also assumed the existence of NIZK (Non-Interactive Zero Knowledge) Range Proof for ballot correctness in their system; the implementation of *ElectionGuard* v.2 (open source) used **disjunctive Chaum-Pederson** Range Proof³³.

-We could add that whatever the underlying cryptography is, ZKPs that are based on the discrete logarithm problem (like *bullet proofs* and *Chaum-Pederson*) enjoy faster prover time than general purpose SNARKs. This is a desirable quality for ballot validity proof since the voting application is the prover (the vote collector is the verifier); the prover code must be executed online during the voting session and cannot be batched or pipelined even if the used ZKP allows it.

-However, a recent paper, [51], (a follow up to *Kryvos* referred to by [14] in the subject) introduced benchmarks for an efficient implementation of *Groth16* over El-Gamal based voting systems. The authors used a 254-bit common elliptic curve BN254 in their implementation, while IVXV uses 384-bit curve; it is also worth

³² The last few lines in the question (<https://stackoverflow.com/questions/35301392/how-to-access-a-remote-desktop-from-a-virtual-machine-set-on-a-server>) show that similar things have been done, and (<https://serverfault.com/questions/229216/application-which-can-pop-up-like-gtalk-when-some-one-accesses-my-server>). Also, any other service in the Estonian e-government that links electronic IDs to cellular numbers or emails can receive just the voter ID to send a fixed message “Beware you are not using the official voting application”.

³³ <https://github.com/microsoft/electionguard-rust/blob/main/TODO.txt#L1373>

noting that the circuit specific setup needed in Groth16 could be considered a drawback.

-Another 2024 paper, [52], introduces *Polymath* proving it can be more efficient than Groth16 and relates it to KZG commitments³⁴. Here, the authors did compare KZG and Groth16 over a 381-bit curve (BLS12-381) which is closer to the one used in IVXV; their work also included mathematical proofs for batching reductions.

Finally, all of this will have to be rethought-of seeking post-quantum validity proofs. There are many post-quantum NIZKs and SNARKs, but the choice must be compatible with the new post-quantum encryption that will be used.

6.4 Insiders' Risk (The Number of Ballots)

We mentioned in section 5.2 that a solution was already implemented to overcome insiders' risks at the processing stage. However, the integrity of the input file still depends on the vote collector and registration application not to collude, which is also an insiders' risk; for example, the Count values are not cryptographically proved. For this vulnerability, we suggest two alternatives; the first depends on checking the consistency of different data sources available in the Estonian government.

Overall Checks

This solution aligns with IVXV solution discussed in section 5.2, since the *PKIX* timestamp protocol³⁵ is used to both record the time of casting the vote and to register the electronic vote in an external independent service. So, instead of trusting the initial *Count* value coming from the vote collector and the registration service, extends to check it with other data records available in the Estonian e-government.

-A possible general double check for the whole list of votes is to compare with the transaction records of the Estonian Information System. In fact, there is an existing *myID* service, [53], that provides what could be viewed as an individual verifiability double check for voters using the eID digital identity³⁶. We suggest that IVXV performs similar universal verifiability checks on all votes; i.e., checking that the total number of transactions to IVXV services equal the total number of existing ballots. Recalling Eq(1), we add the check:

Verify:

Count (original votes file) =

³⁴ While comparing different ZKPs for ballot validity is a rich area to pursue as an extension to [51], researchers who are not on that track can find a condensed summary and a comparison between possible SNARK choices in the first 25 mins of (<https://youtu.be/A3edAQDPnDY>)

³⁵ PKIX is a timestamping protocol that enables a trusted third party can confirm the existence of data at a specific point in time with its signature ().

³⁶ In the context of doubting the effectiveness of multiple voting as a protection from vote buying/coercion, [9] shows and demonstrated through X conversation (<https://x.com/trtram/status/1763936733027049606>) how a sophisticated user can do that.

Count_Transactions (source=all, destination=IVXV, time=election_interval)

-If there exist aggregating queries on the information system, the same above check should be repeated for checking the integrity (not just the count) of all votes. The verification process could be a simple hash cascade, a sophisticated ZKP, or even a comparison between sorted versions of the common fields between the two lists:

Verify:
 (original votes file) =
Transactions (source=all, destination=IVXV, time=election_interval)

-If aggregating queries were not possible, the first check could be accompanied by some kind of **Risk Limiting Audits (RLA)s**, where only a sample of random votes could be selected to check manually. RLAs are usually used in e-voting systems that deploy dual paper ballots, [54]; here, transactions stored in the Estonian information system could play the role of paper ballots to compare with IVXV data.

for all $i \in \text{sample}$
 {
 $n = \text{Count}(\text{original votes file}, \text{vote_ID}=i);$
 Verify:
 $n = \text{Count_Transactions}(\text{source}=i, \text{destination}=IVXV, \text{time}=\text{election_interval});$
 for all $j = 1$ to n //in time order
 Verify:
 $\text{Original votes file}(\text{vote_ID}=i, \text{order}=j) = \text{Transaction}((\text{source}=i, \text{destination}=IVXV);$
 }

6.5 The proposed Verkle Tree

A more robust protection from insiders' risk is to construct an online SNARK with each vote; i.e., cryptographically commit to the vote spontaneously. This choice can be also favorable if the Estonian government does not prefer the interaction between the e-voting system and other e-government entities, and yet care to cryptographically prove the counter values (for each voter and for the whole number of votes) in addition to the data integrity.

We suggest aggregating vote hashes in an Authenticated Data Structure ADS [55, sec.2.1 def.3] which we can simply describe as data structures that can provide succinct (short) cryptographic proof (sometimes called witness) of each element stored in them and that can cryptographically prove the number of values stored in it. In fact, [37] has earlier suggested as a protection from privacy attacks that each voter computes a *NIZKP of knowledge* of his/her encrypted vote, and the newer version of IVXV partially responded. Currently, the Registration Service sends *hash(vote)* to the Ballot Processor (Fig.s 3&5). Tracing the code in [40, line 239], vote hashes are stored in a *Treebag* which represents a binary search tree data structure in Java; i.e., even if it reflected a Merkle tree design, the number of nodes in the tree (votes) is not cryptographically verified.

In this paper, we suggest the use of **Verkle Trees** [56], which is a vector data structure that authenticate its elements based on KZG polynomial commitments (as

the polynomial coefficients) because they have the shortest verifying complexity (constant order), more important because they provide a cryptographic proof of the number of elements stored in them (as opposed to Merkle Trees) which is the number of votes in our case; also, the data structure could be virtual, only the needed proves have to be kept in storage after runtime. The longer prover time for general purpose SNARKs, mentioned in section 6.3, is not as problematic here, since proofs can be constructed in the background and /or batched using the homomorphic property. Hence, we propose to aggregate all votes in a Verkle Tree (VT); every used Verkle Tree will add a line or 2 to the code $\{VT=VT+H[i] * committed_vote; i++;\}$, where the vector H is calculated during setup (Appendix A.1).

-If this was used in conjunction with the solution in section 5.2, then we are done here; the Ballot Processor can verify the VT value in its first block (Fig.5), and RLA samples can be verified similarly. If the VT value were published instantaneously when the voting is closed, and the original list of all votes hashes is also available, even independent anonymous verifiers can verify it too. It is also important to make the code publicly available to guarantee the integrity of the VTs construction steps.

-If this solution is to be used to further validate the removal of multiple votes, then it must construct another dynamic final votes VT_2 in parallel; votes from the same voter could be moved to aggregate in second level VTs if needed or accumulated all into a third VT_3 otherwise. There could be a variety of ways to implement this idea depending on the needed checks; see Appendix A and Fig.6 for the details, where only step1 is needed in conjunction with [40].

Discussion

Authenticated Data Structures (ADSs) are proposed here as a mean to remove trust assumptions of voting modules by publishing SNARK values that were dynamically calculated using a publicly available code. In this paper, we chose Verkle Tree commitments as opposed to Merkle Trees or STARKs based on the following logic.

-Verkle Trees provide a constant order complexity SNARK (per node or per batch that could be all the data) using KZG vector polynomial commitments. Although Verkle Trees require trusted setup procedure to generate a crs (*common reference string*), but we do not consider this a problem since it is a universal setup (not circuit specific as in Groth16) which aligns with IVXV setup & key generation phase. This arrangement also allows the use of *Risk Limiting Audits (RLAs)* to verify the details of a selected sample if interaction with other e-government information systems is not favorable.

-Traditional Merkle Trees provides logarithmic complexity proofs on the data stored in their leaves; i.e., can support checking samples too although at higher complexity (not an issue since RLA checks are done offline). However, Merkle trees do not verify the numbers which are crucial in our case.

-Although the STARKs (*Scalable Transparent ARguments of Knowledge*) option introduced in [55] is based on FRI commitments and hence provides post-quantum security guarantee, and also does not require a trusted setup phase, we find those advantages helpless in our case; IVXV involves a key setup phase anyway, and deploys EL-Gamal encryption which is not post-quantum to begin with. In their paper, the authors showed a projected performance analysis for applying their

approach to EL-Gamal based e-voting systems, but it is not a performance issue; if quantum computing is feasible, an adversary can discover the private keys and produce correct values that will pass the verifier checks. Hence, we believe STARKs can only be a better solution if they were a suitable match with a post-quantum update of the underlying encryption.

Finally, there is an interesting intuition from [55] that can be useful in archiving IVXV results. Their suggestion to make the verifier check the generated proof instead of the original data can be used when election data gets destroyed (after a month); i.e., the VTs generated in Appendix A could be kept forever as permanent proof.

6.6 Post Quantum Cryptography (PQC)

Quantum computing depends on physics and quantum mechanics to perform computations much faster than current existing hardware that it could break all problems we currently consider infeasible to break including the Discrete Logarithm Problem and Elliptic Curve cryptography in general. Cryptography researchers discussed it³⁷ [57,58] and cared to provide zero knowledge proofs like STARKs mentioned above in [55].

Main Solution Strategies

The ENISA (The European Union Agency for Cybersecurity) 2021 report, [59], was dedicated to post quantum solutions with a focus on the 3 finalists of NIST round at that time. Suggested solutions [58,59] are based on **multivariate** equations over a finite field (ex. UOV and Rainbow), others are based on **error correcting codes** (ex. McEliece), but most are based on **Lattice** cryptography (ex. CRYSTALS-Kyber) and/or **Hash** functions since hashes can be quantum-resistance with larger output size³⁸. **Lattices**, [60], can be viewed as n -dimensional matrices (represent discrete points in an n -dimensional space); this can provide problems that remain hard to compute even with quantum computers like *Shortest Integer Solution (SIS)* and *Learning With Errors (LWE)*. On July 2022 NIST announced the final choice of Lattice-based standards for post-quantum digital signatures and public key encryption; security analysis of CRYSTALS-Kyber, the selected standard for public key encryption and key establishment, including vulnerabilities and an AI-based *side channel* attack³⁹ can be found in [61,62].

³⁷ In fact, papers presenting post quantum solutions are there since 1978 (Robert J. McEliece, “A public-key cryptosystem based on algebraic coding theory”, 1978. JPL DSN Progress Report http://ipnpr.jpl.nasa.gov/progress_report2/42-44/44N.PDF.)

³⁸ The 2016 NIST report stated that Symmetric key encryption can tolerate by increasing the key size, and that SH-2, SH-3 hash functions can be quantum resistance by increasing the hash length, [58]; in any case, hashes are treated as oracles in most designs, which means they can be replaced by post quantum ones without much disruption.

³⁹ From [61], side-channel attacks were first identified by Paul Kocher in 1996 as *Timing attacks* on implementations. They make use of data that are disclosed while a cryptographic device is in use; this information might be in the form of electromagnetic radiation, sound waves, power use, or execution time (how they reflect the data).

Threat is Approaching

-Other than research, whether independent or cooperated, Quantum computers remained just a theoretical threat that is infeasible to implement; even when believed otherwise, as of May 2024, none of the interviewed experts in [63] expect upgrading embedded infrastructure devices to take less than ten years⁴⁰. However, things got accelerated at the end of last year; on Dec 2024, Google unveiled its first chip [64]; on April 2025 a quantum computing group [65] offered a 1 BTC (84,000\$-100,000\$; i.e., anticipated cost is not very large) reward competition to break a Bitcoin key using quantum computing within a year. European financial corporations announced \$1bn investments plans on post-quantum cryptography (PQC) in 2025 [66], as opposed to \$162.8m value in 2024 [67].

-In general, the retaliation game for political elections is more severe than that of financial systems; some countries are willing to pay much more to break a political election than a thief wanting to steal money, or even an evil competitor wanting to break a cryptocurrency. Hence, all countries deploying e-voting systems should be more pressured to provide post-quantum solutions. When [63] stated that most interviewed experts do not believe elections would be the main target of a quantum adversary, this is because those countries have also e-governments; they are more worried of a complete collapse if their digital ID systems were attacked for example.

Estonian Quantum Efforts

For our specific case of Estonia, the authors of [63] included 5 out of 24 experts from Estonia in their interviews, and covered steps taken by the Estonian government [63/2.2.2] in different quantum related aspects; a European cooperation to deploy a quantum communication infrastructure in 2020 [68] which led to the NordIQEst (*Nordic-Estonian Quantum Computing e-Infrastructure Quest*) in 2022 [69], a collaboration between *Cybernetica* (IVXV company) and University of Tartu to create post quantum solutions has started in 2021 [70] including jointly supervised doctoral thesis from which we encountered a paper (2024) on PQC migration obstacles in Estonia [71], and finally PQC is 1 of 6 challenge areas included the Cyber Security hub established in 2023 between Estonia and a major Czech ICT powerhouse both in industry and education [72]⁴¹. Then, the European Commission published on 11 April 2024, [73], a coordinated PQC implementation roadmap for all member countries. The announcement contained only one guiding statement; the implementation should be “*via hybrid schemes that may combine Post-Quantum Cryptography with existing cryptographic approaches or with Quantum Key Distribution*”. This was different from ENISA 2021 report [59/page 35] excluded solutions using QKD based because its setup relies on pre-established authenticated

⁴⁰ Another Estonian research, [71], puts the first obstacle to post quantum transition as: “*The urgency of starting the post-quantum migration is not well understood by decision-makers and those outside the cryptographic community. Multiple parties from the private and public sectors are not contributing enough to the migration process, causing stagnation*”

⁴¹ The project results include one post quantum that is concerned with blockchains (<https://www.scitepress.org/Link.aspx?doi=10.5220/0012112700003555>) which is also part of the Estonian government quantum concerns.

communications channels; [63] also reported different experts' opinions on this point. In fact, [71] considered "*EuroQCI focused attention on QKD technology whose functionality is limited than that provided by PQC*" as an obstacle to post quantum transition.

Estonian I-Voting Related Efforts

-Digital IDs are a crucial element in i-voting; the ENISA July 2024 report [74] on the unified European digital identity project *eIDAS*, though, did not specify the PQC transition details. Then on 19 Feb 2025, [75], *Cybernetica* announced that the first hardware chip enabling post-quantum ID card has been certified in Europe; when asked about post quantum i-voting, they answered "*there is more math to do*". In their 2024 paper [71/], they mentioned a problem with the usage of Hybrid systems in i-voting; in their own words "*we are not aware of any research toward mix-nets for hybrid encryption schemes; using a hybrid encryption scheme with a mix-net that mixes only a single layer of encryption would leak the links between cast and counted votes if/when one of the encryption layers becomes insecure*". Appendix B contains a brief literature survey on post quantum i-voting research attempts, and on some post quantum replacements for El-Gamal encryption.

7 Possible Research Directions

The paper in [51] could be a starting point for researchers concerned with hardware acceleration of Zero Knowledge Proofs that goes in depth into circuit specific details, while [52] would be useful for researchers interested in theoretical cryptographic proofs. Also, research can be further pursued to conduct comparative analysis between possible zero knowledge proofs concerning implementation details along proof batching reductions over the exact 384-bit elliptic curve used in IVXV.

However, one may think the future will promote more research on efficient quantum secure solutions and less encouragement to elliptic curve research. The research space is challenging, [58], on the efficiency-security tradeoff; demanding for new innovations [60] and for cryptanalysis of the new "not studied enough" protocols [61,62]. In addition, AI-based attacks could be another rich research area that is relatively new to engage with research in cryptography (although familiar in anomaly-based attack detection); as stated in [62] "*how information can be leaked from the implementation of a cryptographic component and how the leaked information can be used to exploit an algorithm*".

Finally, with the intuition of [46] and [48], it could be an interesting research to tackle the broader question of *to what limit can the information provided by general purpose activity logs of digital identities* (in Estonia or any country that uses digital identities in online voting) *help vote buyers and/or coercers* in catching voters who try to deceive them, and whether a blockchain based e-government is an advantage or disadvantage in that direction. We have already discussed in section 6.4 how [53] and similar services can impose this trade off; to what limit could adversaries expand their

toolbox using such services to defeat the *CK* (*Complete Knowledge*) metric suggested in [47] whether for vote buying/coercion or any other malicious activity.

8 Summary & Conclusions

In this paper we gave a political and technological historical brief on the development and status quo of the Estonian internet voting system. Then we explained the current system architecture and surveyed available material from the academic literature and different other available resources to cover reported attacks and/or vulnerabilities and how they were fixed by the system. Last but not least, we discussed remaining vulnerabilities; mainly, authenticating the voting application and cryptographically proving the list of votes against any possible insiders' manipulation. We suggested some possible solutions that give voters the freedom to deliberately use a different voting application they trust more; the first is allowing the voter to check the application fingerprint prior to voting; the second is allowing only a list of pre-registered applications (through digital signatures) and informing the voter with the result. Then, we proposed alternatives for more robust guarantees that the list of votes was not manipulated inside the system; one is to perform consistency checks and RLAs between ballots in IVXV and with digital transactions interacting with IVXV through the Estonian Information System. The second is aggregating votes (online during the voting process) in authenticated data structures like STARKs or Verkle Trees which we detailed as our proposed solution. Finally, we highlighted the quantum computing threat on e-voting systems, and digital identities in general, then introduced a variety of possible research threads that could evolve from all the introduced material.

Acknowledgements

I'm grateful to everyone participated in making me acquire this level of knowledge & research skills: from my graduation faculty Alexandria Computer Engineering department 30 yrs ago (the encouragement of *Prof. Nagwa Elmekky*, and the guiding soul of the belated *Prof. Ahmed Belal*), to everyone who has put their work free online (Berkeley ZKP MOOC, HAL, iacr, arXiv, E-Vote-ID, Tallinn University). Then, a considerable part of the material presented here about observers was reached through *Märt Põder* some way or another; the blog, X (previously twitter) posts and conversations leading to more accounts and data (the team behind [21] and the thesis in [14] were both shared in X). Also, Prof. AGO Samoson shared the recent IEEE article [41] on his Facebook.

References

1. Piret Ehin, Mihkel Solvak, Jan Willemson, and Priit Vinkel, “Internet voting in Estonia 2005–2019: Evidence from eleven elections”, Oct 2022;

- <https://doi.org/10.1016/j.giq.2022.101718>;
<https://www.sciencedirect.com/science/article/pii/S0740624X2200051X>
2. https://osce.org/files/f/documents/f/f/551179_0.pdf
 3. <https://www.smartmatic.com/featured-case-studies/estonia-the-worlds-longest-standing-most-advanced-internet-voting-solution/>; last accessed 30/6/2024.
 4. <https://gafgaf.infoaed.ee/en/posts/great-divide-in-evoting/>; last accessed 14/3/2024.
 5. <https://ausadvalimised.ee/docs/yhisavaldus2023/>; and newer petitions in 2024: <https://ausadvalimised.ee/ei-lepi-vaadeldamatusega/>, last accessed 13/6/2024; <https://x.com/ausadvalimised/status/1808854585597108552>, last accessed 5/7/2024.
 6. <https://electionsnovascotia.ca/PictouWestByElectionEBallot>, last accessed 22/4/2024.
 7. Stone Bridge, "About the destruction of Eestlus on the example of the Central Party", <https://uueduudised.ee/arvamus/kivisildnik-eestluse-havingust-keskerakonna-naitel/>; last accessed 14/1/2024.
 8. "A computer scientist made available the code for e-elections, which the electoral service has so far been fiercely hiding", <https://digi.geenius.ee/eksklusiiv/arvutiteadlane-tegikattesaadavaks-e-valimiste-koodi-mida-valimisteenistus-on-seni-kiivalt-varjanud/>; last accessed 2/1/2024.
 9. <https://gafgaf.infoaed.ee/en/posts/perils-of-electronic-voting/>; last accessed 4/1/2024.
 10. https://media.ccc.de/v/37c3-12298-should_e-voting_experience_of_estonia_be_copied#t=965; last accessed 15/1/2024.
 11. "The use of e-voting should be limited, <https://arvamus.postimees.ee/7974894/mart-poder-e-haaletuse-kasutust-tuleks-piirata>; last accessed 13/3/2024.
 12. Election Commission of the Republic, "Resolution of Andres Alla's complaint", 21.06.2024 No. 14, <https://www.riigiteataja.ee/akt/322062024003>; last accessed 5/7/2024.
 13. <https://www.valimised.ee/en/internet-voting/observing-auditing-testing>; last accessed 5/7/2024.
 14. Taaniel Kraavi, "Proving Vote Correctness in the Estonian Internet Voting System", Master thesis, Tallinn University of Technology, June 2024, <https://digikogu.taltech.ee/et/Download/ffdf0de1e58d455ba3d484400c9123fc.pdf>
 15. "A transparent digital ballot box can be tried in the e-voting threshold survey", <https://ausadvalimised.ee/uuenduslik-exitpoll/>; <https://github.com/infoaed/pseudovote-euro24/tree/JUNE5TH2024>; last accessed 5/7/2024.
 16. Ago Samoson, "The developers of our e-election system could admit their strategic mistake in order to prevent the worst", 17/3/2024, <https://arvamus.postimees.ee/7981474/ago-samoson-valimishavingut-tuleb-ennetada>; last accessed 9/7/2024.
 17. "E-voting system Disk appeared out of nowhere", <https://gafgaf.infoaed.ee/posts/esoteeriline-turvamudel/>; last accessed 22/5/2024.
 18. Smartmatic-Cybernetica. IVXV Voting Service. Version 1.8.2-RK2023, <https://github.com/valimised/ivxv/tree/master>
 19. Election Commission of the Republic, "Review of Mart Podra's Complaint", 23/2/2023, <https://www.riigiteataja.ee/akt/328022023004>; last accessed 7/7/2024.
 20. The report of the cyber security committee of the Academy of Sciences, <https://x.com/danbogdanov/status/1802998209649762582>; last accessed 6/7/2024.
 21. Cyber Security Commission minutes of meetings, <https://www.akadeemia.ee/akadeemia/noukogud-ja-komisjonid/kuberturvalisuse-komisjon/>; last accessed 7/7/2024.
 22. <https://ec.europa.eu/digital-building-blocks/wikis/pages/viewpage.action?pageId=533365949>; last accessed 28/12/2023, <https://scoop4c.eu/cases/estonian-internet-voting>; last accessed 22/11/2023.

23. Arnis Parsovs, "Estonian Electronic Identity Card: Security Flaws in Key Management"; video <https://www.usenix.org/conference/usenixsecurity20/presentation/parsovs>
24. Arnis Parsovs, "Estonian Electronic Identity Card: Security Flaws in Key Management", 29th USENIX Security Symposium, Aug 2020, 978-1-939133-17-5.
25. Arnis Parsovs, "Estonian Electronic Identity Card and its Security Challenges", PhD Thesis, University of Tartu.
26. Geenius. The police discovered 15,000 faulty ID cards, over 300 have been used (in Estonian), June 2019. <https://digi.geenius.ee/rubriik/uudis/politsei-avastas-15-000-veaga-id-kaartide-300-on-kasutatud/>; last accessed 20/3/2024.
27. Matus Nemec, Marek Sys, Petr Svenda, Dusan Klinec, Vashek Matyas, "The Return of Coppersmith's Attack: Practical Factorization of Widely Used RSA Moduli", CCS '17: Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security, pages 1631 - 1648, <https://dl.acm.org/doi/10.1145/3133956.3133969>
28. <https://e-estonia.com/raulwalter-estonia-digital-identity-giant/>; last accessed 20/3/2024
29. <https://e-estonia.com/estonia-introduced-a-new-id-card/>; last accessed 20/3/2024.
30. Jan Willemson, "Creating a Decryption Proof Verifier for the Estonian Internet Voting System", ARES 2023, Italy, ACM ISBN 979-8-4007-0772-8/23/08, <https://doi.org/10.1145/3600160.3605467>
31. Anggrio Sutopo, Thomas Haines, Peter Rønne. "On the Auditability of the Estonian IVXV System and an Attack on Individual Verifiability". Workshop on Advances in Secure Electronic Voting, May 2023, Bol, brac, Croatia. hal-04216242; <https://halscience/hal-04216242>
32. Olivier Pereira, https://www.researchgate.net/publication/372570425_Individual_Verifiability_and_Revoting_in_the_Estonian_Internet_Voting_System
33. <https://valimised.ee/sites/default/files/2023-02/IVXV-protocols.pdf>; newer, IVXV 1.9.10, in Est language: <https://www.valimised.ee/sites/default/files/2024-05/RVT%20korraldus%20nr%2012%20lisa%20%28IVXV-arhitektuur%29.pdf>
34. <https://news.err.ee/1609194064/mobile-voting-likely-to-arrive-in-estonia-in-2025>; last accessed 14/12/2023.
35. <https://github.com/valimised/ivotingverification/blob/published/app/src/main/java/ee/vvk/ivotingverification/util/ElGamalPub.java#L77-L83>, and <https://github.com/valimised/ios-ivotingverification/blob/published/VVK/Crypto.m#L141-L146>; last accessed 20/2/2024.
36. The key application, IVXV 1.9.10 EP2024, <https://github.com/vvk-ehk/ivxv/tree/master/key>; last accessed 8/7/2024, the protocols PDF: <https://www.valimised.ee/sites/default/files/2024-05/RVT%20korraldus%20nr%2012%20lisa%20%28IVXV-protokollide%20kirjeldus%29.pdf>.
37. Müller, J. (2023). "Breaking and Fixing Vote Privacy of the Estonian E-Voting Protocol IVXV", In: Matsuo, S., et al. Financial Cryptography and Data Security. FC 2022 International Workshops. FC 2022. Lecture Notes in Computer Science, vol 13412. Springer, Cham. https://doi.org/10.1007/978-3-031-32415-4_22
38. <https://www.valimised.ee/en/archive/statistics-about-internet-voting-estonia>; last accessed 29/2/2024.
39. Krips, K., Snetkov, N., Vakarjuk, J., Willemson, J. "Trust Assumptions in Voting Systems". In: Katsikas, S., et al. Computer Security. ESORICS 2023 International Workshops. ESORICS 2023. Lecture Notes in Computer Science, vol 14399. Springer, Cham, https://doi.org/10.1007/978-3-031-54129-2_18; full paper available at <https://arxiv.org/pdf/2309.10391>

40. <https://github.com/valimised/ivxv/blob/published/auditor/src/main/java/ee/ivxv/audit/tools/IntegrityTool.java>; last accessed 24/2/2025.
41. Tarvo Treier and Kristjan Duuna, “*Identifying and Solving a Vulnerability in the Estonian Internet Voting Process: Subverting Ballot Integrity Without Detection*”, IEEE Access, Vol.12, <https://ieeexplore.ieee.org/document/10811882>; published 23/12/2024, last accessed 13/4/2025
42. https://github.com/DrShymaa2022/articles_papers/blob/main/Letter_to_Estonia_ivoting.pdf
43. [https://github.com/valimised/ivxv/blob/published/voting/internal/sessionstatus/rpc/client.go\(#L22,#L103\)](https://github.com/valimised/ivxv/blob/published/voting/internal/sessionstatus/rpc/client.go(#L22,#L103)); last accessed 14/4/2025.
44. <https://x.com/i/grok?conversation=1902860748558135338>; last accessed 14/4/2025.
45. <https://www.valimised.ee/en/internet-voting/documents-about-internet-voting>; last accessed 17/4/2025.
46. PMPhilip Daian, Tyler Kell, Ian Miers, and Ari Juels; July 2018; <https://hackingdistributed.com/2018/07/02/on-chain-vote-buying/>
47. James Austgen, Andrés Fábrega, Sarah Allen, Kushal Babel, Mahimna Kelkar, Ari Juels, “*DAO Decentralization: Voting-Bloc Entropy, Bribery, and Dark DAOs*”, Nov 2023; <https://arxiv.org/abs/2311.03530>; <https://github.com/DAO-Decentralization/dark-dao/tree/main>; last accessed 20/3/2024.
48. P. Ronne, T. Finogina, and J. Herranz, “Expanding the Toolbox: Coercion and Vote Selling at Vote Casting Revisited”, E-Vote-ID 2024, Springer Verlag, DOI:10.1007/978-3-031-72244-8_9
49. <https://bitcoinelectrum.com/how-to-verify-your-electrum-download/>, <https://en.bitcoin.it/wiki/Electrum#:~:text=8%20References-Verifying%20Electrum%20Binaries,files%20were%20not%20tampered%20with;> last accessed 17/3/2025
50. J. Benaloh, M. Naehrig, O. Pereira, and D. S. Wallach, “*ElectionGuard: a Cryptographic Toolkit to Enable Verifiable Elections*”, June, 2024, <https://eprint.iacr.org/2024/955>, <https://www.electionguard.vote/spec/>; last accessed 13/7/2024.
51. N. Huber et al, “*ZK-SNARKs for Ballot Validity: A Feasibility Study*”, E-Vote-ID 2024, pp 107-123, Oct 2024; https://link.springer.com/chapter/10.1007/978-3-031-72244-8_7
52. H. Limpaa, “*Polymath: Groth16 Is Not The Limit*”, CRYPTO 2024, pp 170-206, Jun 2024; https://link.springer.com/chapter/10.1007/978-3-031-68403-6_6
53. <https://myid.skidsolutions.eu/en>; last accessed
54. RLAs
55. Max Harrison and Thomas Haines, “On the Applicability of STARKs to Counted-as-Collected Verification in Existing Homomorphically E-Voting Systems”, Mar 2024; https://fc24.ifca.ai/voting/papers/Voting24_HH_On_the_Applicability_of_STARKs_to_Counted-as-Collected_Verification_in_Existing_Homomorphically_E-Voting_Systems.pdf
56. Zero Knowledge Berkely MOOC 2023, lecture 5, “*KZG polynomial commitment scheme*”; <https://youtu.be/tAdLHQVWIUY>
57. Bello A. Buhari, Afolayan A. Obiniyi, Sahalu Junaidu, and Abubakar Roko, “*Elgamal Cryptographic Scheme based on Quantum Key Distribution (QKD)*”, Dec 2020, DOI: 10.47310/iarjet.2020.v01i04.008, https://www.researchgate.net/publication/344784508_Elgamal_Cryptographic_Scheme_based_on_Quantum_Key_Distribution_QKD
58. T. Niraula et al., “*Quantum Computers’ threat on Current Cryptographic Measures and Possible Solutions*”, Oct 2022, International Journal of Wireless and Microwave Technologies 12(5):10-20, DOI:10.5815/ijwmt.2022.05.02,

- https://www.researchgate.net/publication/368394434_Quantum_Computers'_threat_on_Current_Cryptographic_Measures_and_Possible_Solutions
59. <https://www.enisa.europa.eu/publications/post-quantum-cryptography-current-state-and-quantum-mitigation>; last accessed 27/4/2025.
 60. Dana Sairangazhykyzy Amirkhanova, Maksim Iavich, and Orken Mamyrbayev, “*Lattice-Based Post-Quantum Public Key Encryption Scheme Using ElGamal’s Principles*”, Jul 2024, *Cryptography* 2024, 8(3), 31; <https://doi.org/10.3390/cryptography8030031>
 61. Iavich, M. and Kuchukhidze, T., “*Investigating CRYSTALS-Kyber Vulnerabilities: Attack Analysis and Mitigation*”, *Cryptography* 2024; <https://www.mdpi.com/2410-387X/8/2/15>
 62. Grünfeld, J. Mathias H., “*Side-Channel Attacks on CRYSTALS Kyber: An Analysis of a Post-Quantum Algorithm and Its Vulnerabilities to Side-channel Attacks*”, Master’s Thesis, NTNU, Trondheim, Norway, 2023; (cross reference from [60]).
 63. A.R. Perez, N. Costa, and T. Finogina, “*An electoral exception? Quantum computing - readiness and internet voting*”, 31 May 2024, *JeDEM Issue 16 (3)*: 50-79, 2024, DOI: 10.29379/jedem.v16i3.928
 64. Chris Vallance, “*Google unveils 'mind-boggling' quantum computing chip*”, <https://www.bbc.com/news/articles/c791ng0zvl3o>, last accessed 22/4/2025; Google published paper: <https://www.nature.com/articles/s41586-024-08449-y>
 65. <https://www.coindesk.com/tech/2025/04/17/quantum-computing-group-offers-1-btc-to-whomever-breaks-bitcoin-s-cryptographic-key>
 66. <https://digital-strategy.ec.europa.eu/en/news/commission-publishes-recommendation-post-quantum-cryptography>, last accessed 22/4/2025.
 67. <https://uk.finance.yahoo.com/news/europe-post-quantum-cryptography-market-151700764.html>; last accessed 23/4/2025.
 68. <https://www.mkm.ee/en/news/estonia-joined-eus-cooperation-framework-quantum-communication-infrastructure>; last accessed 28/4/2025.
 69. <https://neic.no/news/2022/08/19/nordiquist-has-started/>; last accessed 28/4/2025.
 70. <https://sciencebusiness.net/network-updates/university-tartu-and-cybernetica-cooperate-study-quantum-safe-cryptography>; last accessed 28/4/2025.
 71. J. Vakarjuk, N. Snetkov, and P. Laud, “*Identifying Obstacles of PQC Migration in E-Estonia*”, 2024, <https://ieeexplore.ieee.org/document/10685570>; full paper available at https://ccdcoe.org/uploads/2024/05/CyCon_2024_Vakarjuk_Snetkov_Laud-1.pdf
 72. <https://cordis.europa.eu/project/id/101087529>; last accessed 28/4/2025.
 73. <https://digital-strategy.ec.europa.eu/en/library/recommendation-coordinated-implementation-roadmap-transition-post-quantum-cryptography>; last accessed 27/4/2025
 74. https://www.enisa.europa.eu/sites/default/files/2024-11/Remote%20ID%20Proofing%20Good%20Practices_en_0.pdf; last accessed 22/4/2025.
 75. <https://e-estonia.com/cybernetica-post-quantum-cryptography-joins-to-menu/>; last accessed 28/4/2025.
 76. <https://medium.com/@shymaa.arafat/what-are-verkle-trees-kzgcommitments-and-could-they-be-applied-on-bitcoin-cbf4838d18ac>; last accessed 28/4/2025.
 77. <https://www.wisekey.com/press/wisekey-pki-and-sealsq-post-quantum-technologies-enhance-e-voting-security-through-advanced-cybersecurity-and-ai-integration/>
 78. I. Chillotti, N.s Gama, M. Georgieva, and M. Izabach`ene. “*A homomorphic LWE based e-voting scheme*”, 2016, In *PQCrypto*, volume 9606 of LNCS, pages 245–265. Springer
 79. Rafa`el del Pino, Vadim Lyubashevsky, Gregory Neven, and Gregor Seiler, “*Practical quantum-safe voting from lattices*”, 2017, In *ACM Conference on Computer and Communications Security*, pages 1565–1581. ACM.

80. Guillaume Kaim, Sébastien Canard, Adeline Roux-Langlois, Jacques Traoré, “*Post-quantum Online Voting Scheme*”, FC 2021 - Financial Cryptography and Data Security. International Workshops, Mar 2021, Virtual event, France. pp.290-305, DOI:10.1007/978-3-662-63958-0_25 ;<https://hal.science/hal-03355875>
81. https://www.researchgate.net/publication/360161016_A_Review_of_Cryptographic_Electronic_Voting
82. S. Shriya, J. D. Sweetlin and V. Supraja, “*Secure Online Voting System Using Hybrid Post-Quantum Signatures*,” 2024 International Conference on Advances in Computing, Communication and Applied Informatics (ACCAI), Chennai, India, 2024, pp. 1-7, doi: 10.1109/ACCAI61061.2024.10602388.
83. Hough, Sandsbråten, and Silde , “*More Efficient Lattice-Based Electronic Voting*”, 13-Jan-2025, from NTRUIACR Communications in Cryptology10.62056/a69quhdhj1:4; <https://cic.iacr.org/p/1/4/10/pdf>
84. Bello A. Buhari, Afolayan A. Obiniyi, Sahalu Junaidu, and A.F.D. Kana, “*Enhancement of S13 Quantum Key Distribution Protocol by Employing Polarization Secrete Key Disclosure and Non-repudiation*”, Aug 2023, International Journal of Wireless and Microwave Technologies, https://www.researchgate.net/publication/372769399_Enhancement_of_S13_Quantum_Key_Distribution_Protocol_by_Employing_Polarization_Secrete_Key_Disclosure_and_Non-repudiation

Appendix A: The detailed steps of a complete Verkle Tree (VT) Solution

A.1 Setup:

The election authority picks a random secret T to be destroyed after the end of the setup procedure and calculates (offline) the following terms with a finite cyclic group G that is closed over the used finite field [56,76]; the calculated terms should be public to verifiers:

$$H_0 = G, H_1 = T \cdot G, H_2 = T^2 \cdot G, \dots, H_{p-1} = T^{(p-1)} \cdot G$$

A.2 Steps:

-When a new vote enters the system (through the vote collector and the registration applications), it goes through the following steps (Fig.6):

1. When a new vote record enters the vote collector, in addition to adding it to the votes list, the system cryptographically commits to the vote record by adding its hash to the first Verkle Tree; $VT_1 = VT_1 + \text{Hash}(\text{vote}_i) \cdot H_i$
2. If this voter-ID hasn't appeared before, the new vote hash is aggregated into the second VT as well; $VT_2 = VT_2 + \text{Hash}(\text{vote}_i) \cdot H_i$

3. If it's a repeated voter-ID, then before aggregating it to the second VT, the previous vote must be deleted from it first⁴². The deleted vote is then aggregated into the third VT (or the corresponding second level VT if needed). Since [38] shows that multiple voters are sparse, $O(10,000)$ multiple votes, second level VTs could be implemented as an array holding (voter-ID, VT value)
4. The fact that a voter has voted at the polling station, will not be available during this phase to separate them; if Range proofs were not deployed, then the separation of invalid votes will not be possible at this phase too. However, the Ballot Processor can commit to their values (after separating them as in Fig.6) by calculating VT_4 and VT_5 respectively.

-When i-voting time is closed, make all VT values publicly available in an immutable way; this could be done through the official election site or any trusted robust blockchain.

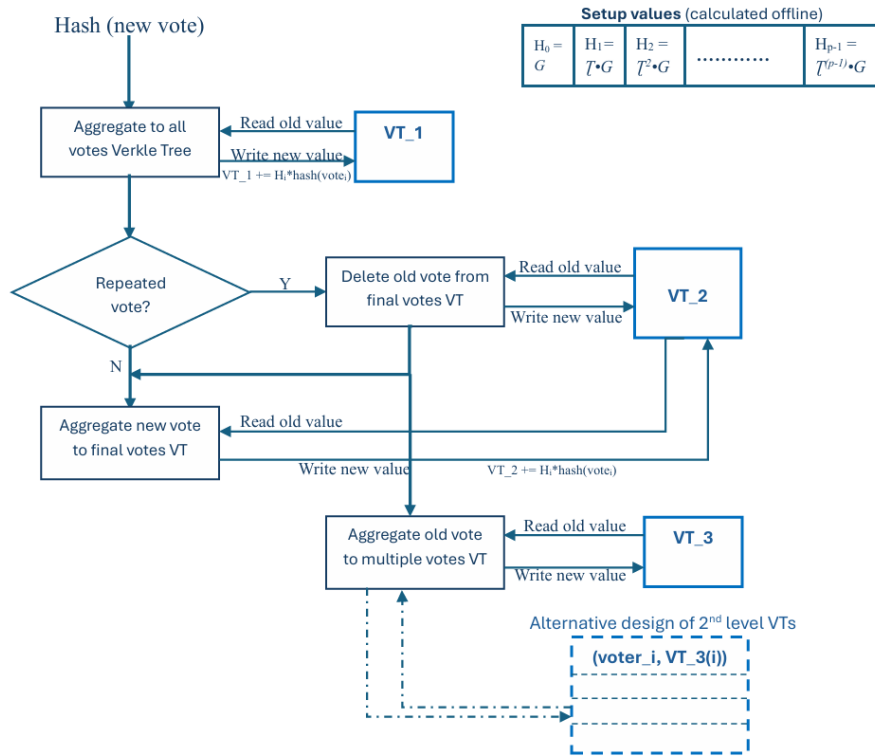


Fig.6: A schematic flowchart of the proposed Verkle Trees design

⁴² We assume the index of the old multiple vote make it retrievable from the list of votes, otherwise step3 will be done by the Ballot Processor; also, this could be done in the background without delaying the interactive processing with voters.

A.3 Results

The proposed Verkle Trees adds the following security values:

- The polynomial degree of each Verkle Tree proves the number of votes it holds (n of a Verkle Tree is cryptographically proved); i.e., two values from Eq.1 in section 5.2: *Count (original votes file)* and *Count (multiple votes)*. The Ballot Processor should check that $VT_1 = VT_2 + VT_3$ ⁴³.
- In addition to the above check, publishing all the VT commitments allows independent verifiers to write their own code to calculate VT_end of anonymized votes. Then, taking advantage of the Homomorphic property of KZG commitments, verify that $VT_{end} = VT_2 - (VT_4 + VT_5)$.
- If RLAs were applied and samples were selected to verify manually, the calculated VT values can also provide separate succinct proof for every sampled value; this is possible whether samples were taken as ballots or as voters. The alternative design of 2nd level VT_3 (Fig.7) may facilitate individual voter verification in a more detailed way; VT_3(i) can prove the number and values of every deleted (multiple) vote for the sampled voters, even if they voted at a poll station afterwards.
- In the 2-levels VT_3 case, **QR codes can include the number of multiple votes** for each voter; this is an extra check against vote manipulation⁴⁴.

⁴³ Addition here means multiplying the two polynomials holding the data, where the resulting polynomial degree (number of committed elements) will be the sum of their degrees.

⁴⁴ There is a maximum of 3 QR code checks, but a voter could vote 10 times and check only the QR of the last vote; in this case our modified QR will reply that “you voted 10 times, your last vote is...”.

Appendix B: A Brief on Post Quantum Online Voting and Replacements of El-Gamal Encryption

B.1 Companies

We have discussed Cybernetica in the main text; [75] explains that they have different countries as customers some of which have 2030 PCQ migration plans, while Estonia is expected to be sooner than that. Another software company, Wisekey located in Switzerland [77], offers its post quantum e-voting services with AI and blockchains as extra lines of defense; however, we did not encounter any real deployment yet.

B.2 PCQ i-voting

There are few earlier attempts, all of which are lattice-based; [78/sections 4.5&6] presented a comparative summary and found, as of 2022, post quantum e-voting research to be *in its initial stages and has not been fully developed*. Also Cybernetica-Tartu paper in 2024 [71] identified “*research lacking on PQC for esoteric use cases such as i-voting*” as one of the obstacles.

Exploring few existing papers, we find [79] from 2016 relied on the honesty of the Bulletin Board and was inefficient for depending on fully homomorphic encryption without ZKPs, then in 2017 [80] deployed ZKPs and proof batching to be more efficient but still the number of needed proofs increases logarithmically with the number of candidates, while [81] (2021) overweighs the election authority trust assumption which is highly unrecommended in the Estonian case. Another 2024 paper [82] that apply Lamport signatures on Merkle data (to decrease the data size); although seems promising, the Merkle tree hash-based signature grows with the number of leaves linearly in the private key size and logarithmically in the signature size (with large constant as well, $256 \cdot \log n$). Finally, we mention [83] from 2025 which is a lattice-based e-voting protocol following the standard mix-and-decrypt framework and supports general ballots.

B.2 PCQ El-Gamal replacements

Although dated in 2020, [57] presented a straightforward solution For El-Gamal based systems where the user(voter)’s public key is encrypted by a symmetric encryption algorithm (Blowfish in [57] but could be AES for more security) and then shared using QKD (*Quantum Key Distribution*); the same quantum key is used for the symmetric encryption. In this arrangement the resulting public key can only be used once, which may complicate multiple voting; the future work of [57] included the use of S13 QKD which can perform the encryption and public key sharing in one step, then they introduced further enhancement, [84] on S13 in 2023.

Another newer (2024) alternative for El-Gamal replacement that aligns better with ENISA recommendations and NIST final standards is introduced in [60]; a lattice-based scheme that depends on the hardness of the SIS problem and is coupled with a private-key encryption scheme. Note that the encryption schemes used in both cases must be secure against *Chosen Ciphertext Attack (CCA)*.